Documentation Technique - Vite & Gourmand

Architecture logicielle

L'application suit une architecture **MVC (Modèle-Vue-Contrôleur)** simplifiée en PHP natif :

- **`/public`** : Point d'entrée unique (Index, Assets). Seul dossier exposé sur le Web.
- **`/src/Models`** : Entités et logique de données.
- **`/src/Helpers`** : Services transverses (Calcul Haversine, Mailer, Synchro Mongo).
- **`/views`** : Templates HTML/PHP.

Persistance Polyglotte

J'ai fait le choix d'une architecture hybride pour séparer les préoccupations (SOC) :

1. **MySQL 8.0 (Relationnel) :**
   - **Rôle :** Données transactionnelles critiques.
   - **Garantie :** Propriétés ACID. Utilisation des **transactions PDO** lors du tunnel de commande pour assurer la cohérence entre l'insertion de la commande et la décrémentation des stocks.
2. **MongoDB 7.0 (Documentaire) :**
   - **Rôle :** Business Intelligence (BI) et Statistiques.
   - **Avantage :** Les pipelines d'agrégation (`$match`, `$group`, `$sum`) permettent d'extraire des rapports de vente par menu sans ralentir les requêtes SQL de production.

Sécurité (Normes OWASP)

- **Injections SQL :** Utilisation stricte de l'interface **PDO avec requêtes préparées**. Aucun paramètre dynamique n'est passé directement dans les chaînes SQL.
- **Failles XSS :** Protection via `htmlspecialchars()` sur l'intégralité des sorties utilisateur.
- **CSRF (Cross-Site Request Forgery) :** Génération et vérification de jetons (tokens) de session sur tous les formulaires `POST` (Commandes, Connexion, Profil).
- **Hachage & Authentification :**
  - Mots de passe sécurisés via `password_hash()` avec l'algorithme **BCRYPT**.
  - Régénération de l'ID de session après chaque connexion réussie (Protection contre la fixation de session).

Conformité RGPD & Qualité

```
- **Anonymisation (Soft Delete) :** La suppression d'un compte utilisateur ne détruit pas les données de facturation (légalement obligatoires pendant 10 ans) mais anonymise les champs personnels et désactive l'accès (Champ `est_actif`).
- **Validation de données :** Double vérification des entrées (Regex côté Client en JS et filtrage `filter_var()` côté Serveur en PHP).

## Résilience et API Tierces

Le calcul des frais de livraison repose sur une intégration de l'**API Adresse Gouv.fr** (via cURL) :

- **Logique :** Conversion de l'adresse client en coordonnées GPS -> Calcul de distance par formule de **Haversine**.
- **Mode dégradé (Fallback) :** En cas d'indisponibilité de l'API (Code HTTP != 200), le système bascule sur un **Simulateur Interne (Mock)**. Ce mécanisme garantit que le tunnel de commande n'est jamais bloqué par un service externe.

## Flux de synchronisation MySQL -> MongoDB

À chaque modification d'état d'une commande (ex: passage au statut 'payée' ou 'annulée'), un `StatistiqueHelper` est appelé en PHP pour :

1. Préparer un document JSON structuré.
2. Mettre à jour (ou insérer) la collection `commandes_stats` dans MongoDB.
```